

Healthcare Security Simulation

HIPAA Compliance Review — Findings & Recommendations Report

Prepared as part of an independent security simulation project | Assessment date: August 2026

Executive Summary

This report documents a mock HIPAA compliance assessment conducted against a simulated healthcare clinic environment, built to model the systems, access patterns, and data-handling practices of a small outpatient provider. The assessment focused on three control areas central to the HIPAA Security Rule: access control, data handling, and audit logging.

The simulated environment consisted of a deliberately vulnerable target system (Metasploitable-Target) representing a legacy clinic system, a centralized log monitoring platform (Splunk-SIEM) configured to receive and index system activity, and an assessment workstation (Kali Linux) used to perform vulnerability scanning consistent with a technical security review.

The assessment identified 10 control gaps, 1 partially met control, and 1 fully compliant control area across the three focus areas, along with 15+ technical vulnerabilities of high or critical severity, including one confirmed remotely exploitable backdoor and one trojaned network service. Findings and prioritized remediation recommendations are detailed below.

Scope and Methodology

The assessment simulated a small clinic environment with an intentionally vulnerable Linux-based system (Metasploitable2) standing in for an aging, unpatched clinic workstation or application server. A centralized Splunk instance was configured to receive syslog data from the target system via a forwarding pipeline, enabling log review consistent with the audit control requirements of the HIPAA Security Rule.

Three methods were used to gather assessment evidence:

- Configuration and log review: direct inspection of system authentication logs, privileged command history, and service configuration
- Centralized log analysis: search and review of forwarded system activity in Splunk, including authentication successes/failures and privileged (sudo) actions
- Technical vulnerability scanning: nmap service/version enumeration and targeted vulnerability scripts (nmap --script vuln) against the target system

Findings were evaluated against the applicable HIPAA Security Rule citations under 45 CFR §164.308 (Administrative Safeguards), §164.310 (Physical Safeguards), and §164.312 (Technical Safeguards).

Risk Register

Findings are prioritized below by risk level. Critical findings represent confirmed, actively exploitable conditions; High findings represent significant weaknesses with a clear attack path; Medium findings represent hardening opportunities that reduce overall attack surface.

ID	Finding	Risk	HIPAA Control	Evidence	Recommendation
F-01	vsftpd 2.3.4 backdoor — confirmed remote root shell	Critical	§164.312(a)(2)(iv) — Access Control	nmap --script vuln confirmed CVE-2011-2523 exploitable; shell command returned uid=0(root)	Remove or upgrade the FTP service immediately; disable if not required for clinic operations
F-02	UnrealIRCd trojaned backdoor service running	Critical	§164.312(a)(1) — Access Control	nmap identified known trojaned IRCd version on port 6667 (irc-unrealircd-backdoor)	Remove the service entirely; it has no legitimate clinical function and represents a known malicious backdoor
F-03	RMI registry allows remote class loading (RCE)	Critical	§164.312(e) — Transmission Security	nmap rmi-vuln-classloader flagged default RMI config permitting remote code execution	Disable RMI registry or restrict to loopback/internal-only access; apply vendor security configuration guidance
F-04	Open, unauthenticated root shell (ingreslock)	Critical	§164.312(a)(1) — Access Control	Port 1524 identified as an open bindshell providing direct root access with no authentication	Immediately close this port; investigate how/why it was enabled, as this is not a standard clinic service

F-05	Cleartext credential and data transmission (Telnet, rsh/rlogin)	High	§164.312(e)(1) — Transmission Security	nmap identified Telnet (23) and r-services (512–514) open with no encryption	Disable Telnet and r-services; require SSH (with modern ciphers) for all remote administrative access
F-06	Broken/weak TLS configurations (POODLE, Logjam, Anonymous DH)	High	§164.312(e)(1) — Transmission Security	nmap ssl-poodle, ssl-ccs-injection, and ssl-dh-params scripts confirmed CVE-2014-3566, CVE-2014-0224, CVE-2015-4000 on SMTP and PostgreSQL	Upgrade OpenSSL/TLS libraries; disable SSLv3 and export-grade ciphers; enforce TLS 1.2+ with strong DH group sizes
F-07	No automatic session logoff configured	High	§164.312(a)(2)(ii) — Access Control	Manual review of SSH/console sessions found no idle timeout enforced	Configure automatic logoff (e.g., TMOU for shell sessions, SSH ClientAliveInterval) after a defined inactivity period
F-08	Shared/default credentials instead of unique user IDs	High	§164.312(a)(1) — Access Control	Single shared account (msfadmin) used for all administrative activity; no per-role clinic accounts provisioned	Provision individually assigned accounts per workforce role; disable shared/default credentials
F-09	Web application SQL injection and CSRF exposure	High	§164.312(c)(1) — Integrity	nmap http-sql-injection and http-csrf identified injectable parameters and unprotected login forms on the clinic-facing web application	Apply input validation/parameterized queries; add CSRF tokens to all state-changing forms; engage a web application review prior to production use
F-10	Unrestricted file-sharing and remote execution services exposed	Medium	§164.502(b) — Minimum Necessary	SMB (139/445), NFS (2049), and rpcbind (111) all reachable with no evident access restriction	Restrict these services to only the hosts/subnets that require them; disable entirely if unused
F-11	Session cookies missing HttpOnly flag	Medium	§164.312(e)(1) — Transmission Security	nmap http-cookie-flags found JSESSIONID cookies without HttpOnly across multiple Tomcat admin paths	Set the HttpOnly (and Secure) flags on all session cookies to reduce session-hijacking risk via client-side scripts
F-12	No emergency access (break-glass) procedure defined	Medium	§164.312(a)(2)(i) — Access Control	No documented procedure identified for authorized emergency access to systems containing ePHI	Draft and test a documented break-glass procedure with logging and after-the-fact review requirements

Audit Logging Capability — Positive Finding

Unlike the gaps above, the audit logging pipeline established during this assessment performed well and should be highlighted as a functioning control. A syslog forwarding pipeline was configured from the target system to a centralized Splunk instance, and end-to-end log delivery was validated through direct testing.

The resulting dataset (288 indexed events) successfully captured:

- Privileged access events, including full sudo command lines showing exactly which user escalated to root, when, and what command was run
- Authentication activity, including successful logins and multiple failed login attempts against invalid usernames, each with source IP and precise timestamp
- System and network-level events, including service restarts and interface state changes

This demonstrates the core capability required by §164.312(b): the ability to record and examine activity in systems that would contain ePHI. The primary gap is procedural rather than technical — no formal log review cadence, retention schedule, or alerting rule set has yet been defined, which would be required before this control could be considered fully compliant in a production environment.

Prioritized Remediation Roadmap

Immediate (0–30 days) — Critical Findings

- Remove or patch the vsftpd backdoor, UnrealIRCd, RMI class loader exposure, and ingreslock backshell (F-01 through F-04)
- These represent confirmed, actively exploitable remote access paths and should be treated as an active incident if found in a real production environment

Short-Term (30–90 days) — High-Risk Findings

- Disable cleartext protocols and upgrade TLS configurations (F-05, F-06)
- Implement session timeout and individually assigned user accounts (F-07, F-08)
- Remediate the web application injection and CSRF findings (F-09)

Medium-Term (90+ days) — Hardening and Process

- Restrict unnecessary network services and close unused ports (F-10)
- Apply secure cookie flags across web applications (F-11)
- Formalize a documented, tested emergency access procedure (F-12)
- Define a log review cadence, retention policy, and alerting rule set to move the audit logging control from Partial to fully Compliant

Appendix: Lab Evidence

The following screenshots document the simulated environment and the audit logging evidence referenced throughout this report.

Lab Environment Overview

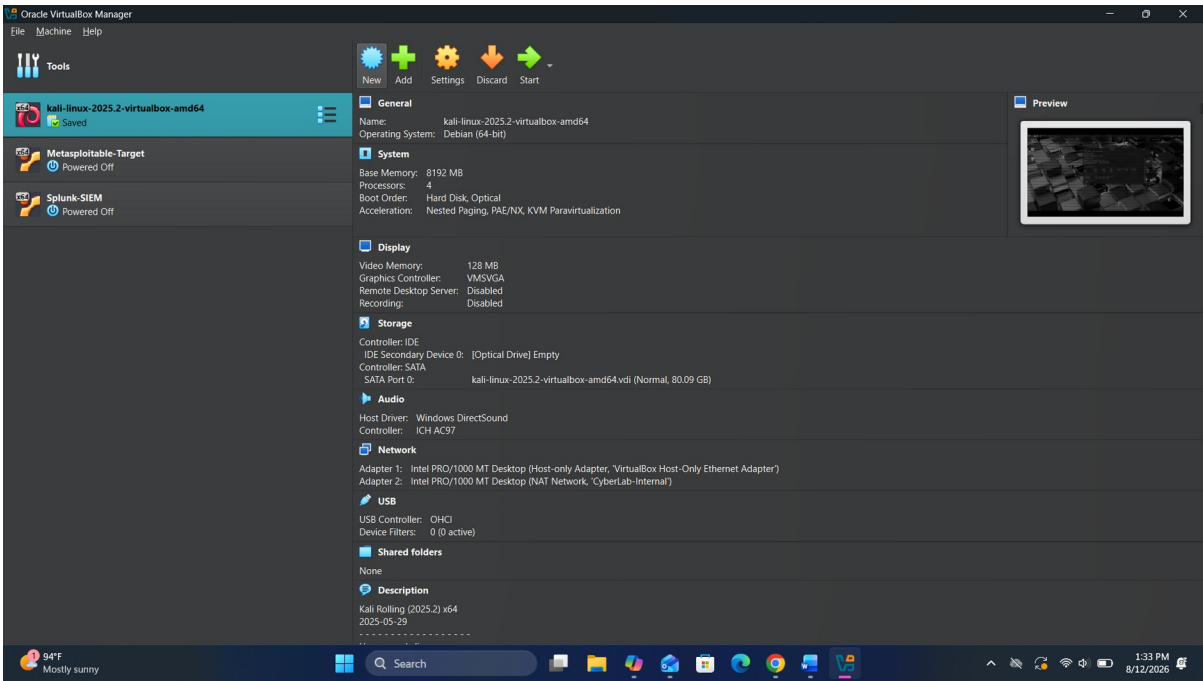


Figure 1. VirtualBox lab environment: Kali (assessment workstation), Metasploitable-Target (simulated clinic system), and Splunk-SIEM (centralized log monitoring platform).

Audit Logging Pipeline Validation

The screenshot below shows the first successful log events received by Splunk-SIEM after the syslog forwarding pipeline was configured, confirming end-to-end delivery from the simulated clinic system.

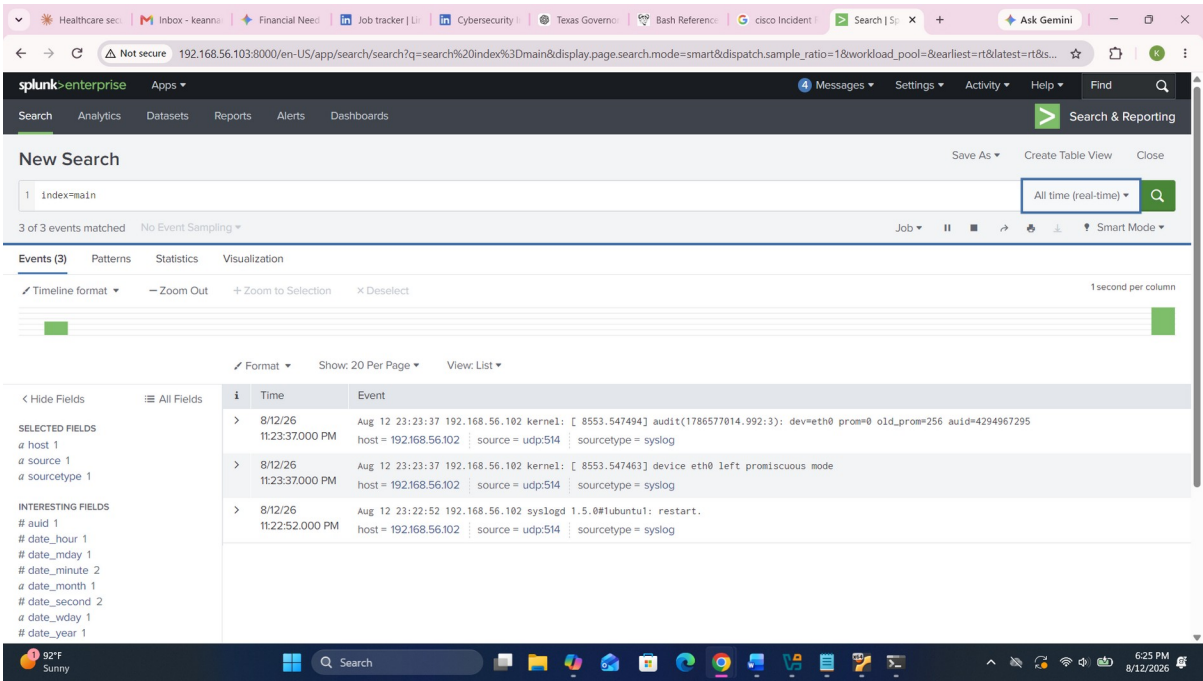


Figure 2. Initial syslog events received in Splunk, confirming the forwarding pipeline from Metasploitable-Target (192.168.56.102) to Splunk-SIEM.

The following event demonstrates the audit trail's ability to capture privileged access with full accountability — showing exactly which user escalated to root, the command executed, and the working directory.

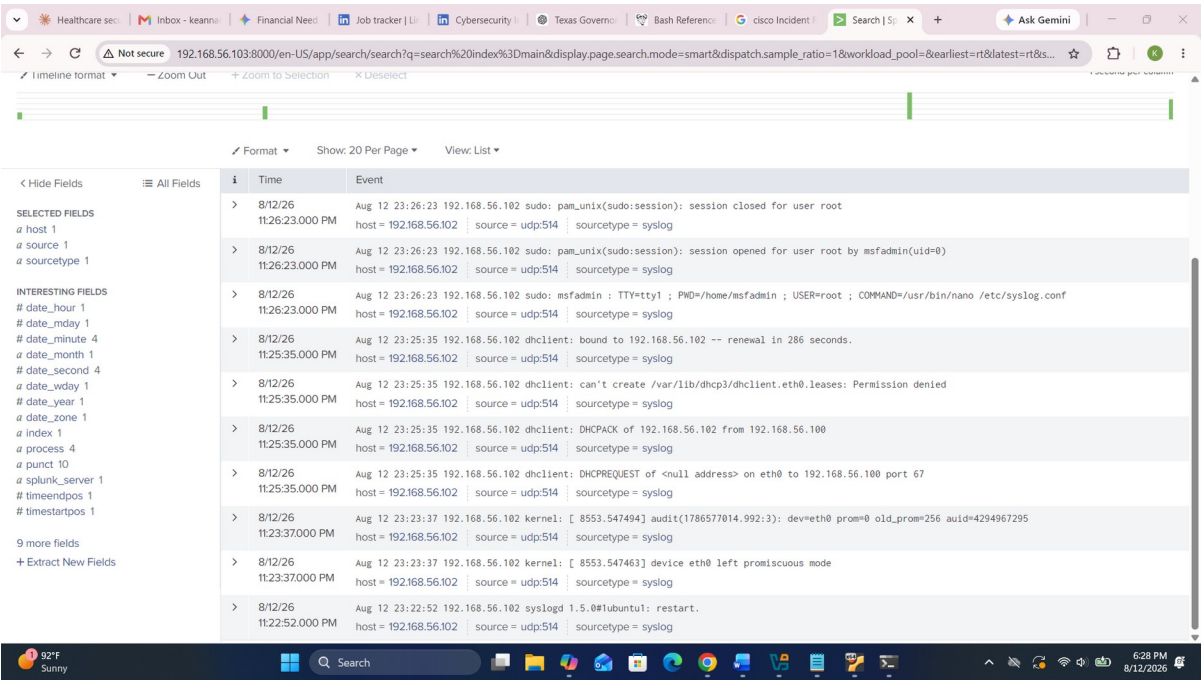


Figure 3. Captured sudo escalation event showing full command-line detail (COMMAND=/usr/bin/nano /etc/syslog.conf), directly supporting §164.312(b) audit control requirements.

By the end of the assessment, the pipeline had indexed 288 total events, providing a substantive dataset for audit log review.

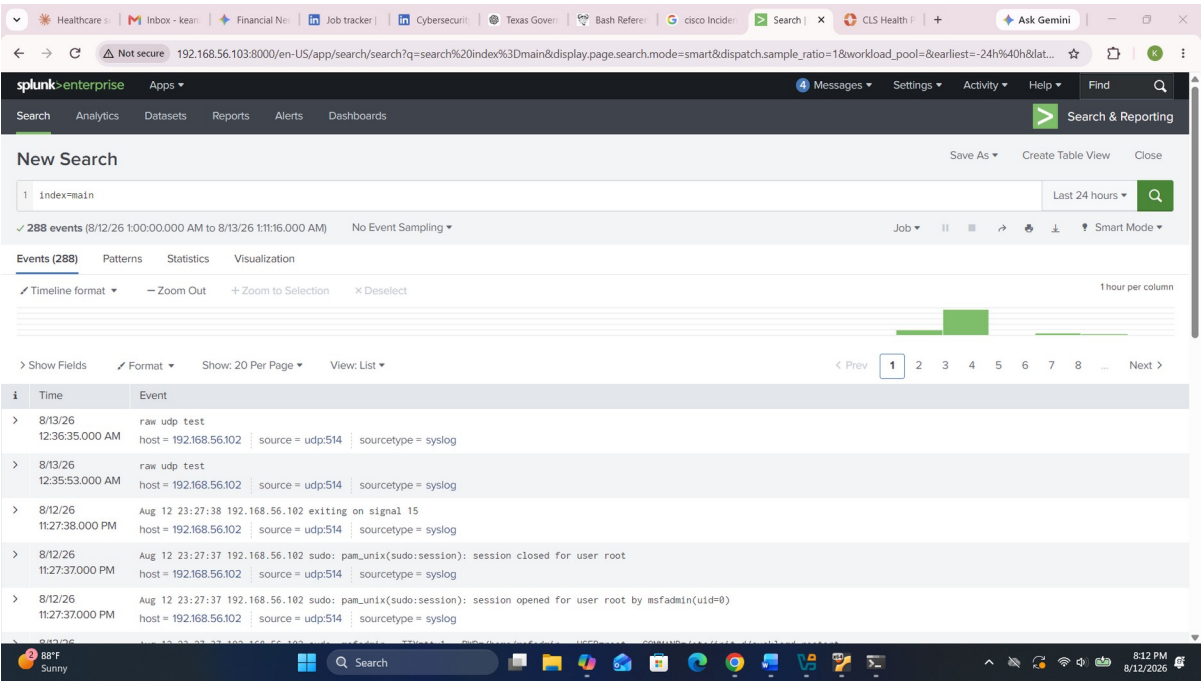


Figure 4. Final indexed event count (288 events) in Splunk-SIEM spanning the full assessment window.